Security Assessment Findings report for testasp.vulnweb.com

Date: 11/11/2026

Project: FUTURE_CS_01

Table of Contents

Table of Contents	2
Confidentiality Statement	3
Disclaimer	3
Contact Information	3
Assessment Overview	3
Assessment Components	4
Finding Severity Ratings	4
Scope	4
Executive Summary	5
Assessment Summary Table	5
1) Insecure connection	6
Recommendation:-	7
2) Clickjacking	8
Recommendation:-	9
3) Sensitive Information Disclosure	10
Recommendation:-	11
4) Missing Content Security Policy (CSP)	12
Recommendation:-	13
5) Insecure Cookie Attributes	14
Recommendation:-	15

Confidentiality Statement

This document is the exclusive property of Future Interns and G. Jagadeeshwar Reddy. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both parties.

I may share this document with evaluators to demonstrate vulnerability assessment requirement compliance.

Disclaimer

A vulnerability assessment is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. I prioritized the assessment to identify weak security configurations. All checks were conducted strictly adhering to read-only ethical standards.

Contact Information

Name	Title	Contact Information
Target Organization		
Acunetix VulnWeb	Test Web Environment	URL: http://testasp.vulnweb.com
Assessor		
G. Jagadeeshwar Reddy	Cyber Security Intern	Phone: 6304214258 Email: jagadeeshguduru006@gmail.com

Assessment Overview

During November 2026, an external read-only vulnerability assessment was performed against `http://testasp.vulnweb.com`. All testing performed is based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (WSTG v4), and customized testing frameworks.

Phases of activities include:

- **Planning:** Rules of engagement obtained and strict read-only scope defined.
- **Discovery:** Perform scanning and enumeration to identify potential vulnerabilities, weak configuration areas, and missing security headers.
- **Reporting:** Document all identified security weaknesses, evidence proofs, and remediation recommendations.

Finding Severity Ratings

Severity	CVSS V3 Score Range	Definition
Critical	9.0 - 10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0 - 8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.

Severity	CVSS V3 Score Range	Definition
Medium	4.0 - 6.9	Vulnerabilities exist but require extra steps or represent cleartext transmission and missing structural browser defenses. It is advised to form a plan of action and patch after high-priority issues.
Low	0.1 - 3.9	Vulnerabilities are non-exploitable directly but reduce an organization's attack surface and eliminate information leakage. Patch during regular maintenance.

Scope

Assessment	Details
External read-only vulnerability assessment	`http://testasp.vulnweb.com`

Executive Summary

During November 2026, a vulnerability assessment was conducted on the website `http://testasp.vulnweb.com`. The tools used for scanning were OWASP ZAP (Passive Mode), Google Chrome Developer Tools, and Nmap. A series of passive checks were carried out to verify potential weaknesses without intrusive exploitation.

Total records generated	Critical	High Severity	Medium Severity	Low Severity
5	0	0	3	2

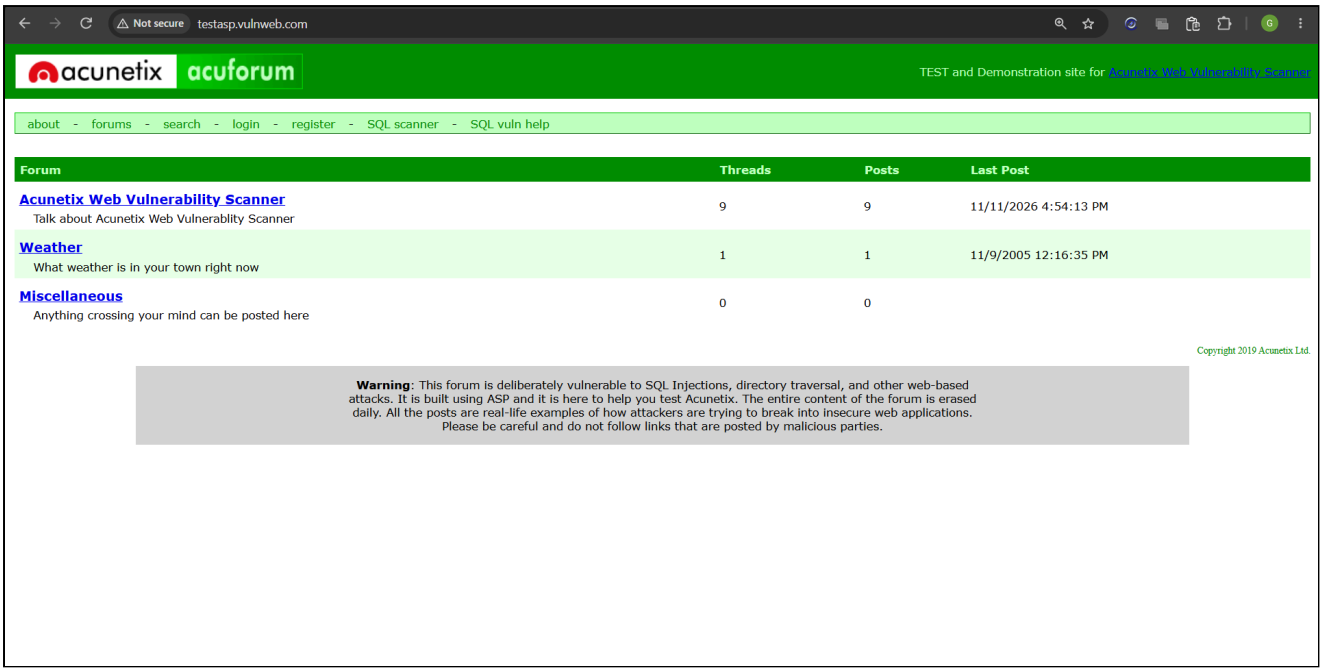
Assessment Summary Table

Sl. no	Observation	Recommendation	Severity
1	Insecure Connection (cleartext HTTP on port 80)	Change webpage to "https" from "http" and configure HSTS	Medium
2	The website is vulnerable to clickjacking (missing framing defense)	Add X-Frame-Options or CSP frame-ancestors	Medium
3	Sensitive Information Disclosure (Server & ASP.NET banner disclosure)	Suppress Server and X-Powered-By response headers	Low
4	Content Security Policy (CSP) header not configured	Implement a robust Content-Security-Policy header	Medium
5	Cookies lack HttpOnly and SameSite security attributes	Set HttpOnly and SameSite flags on all cookies	Low

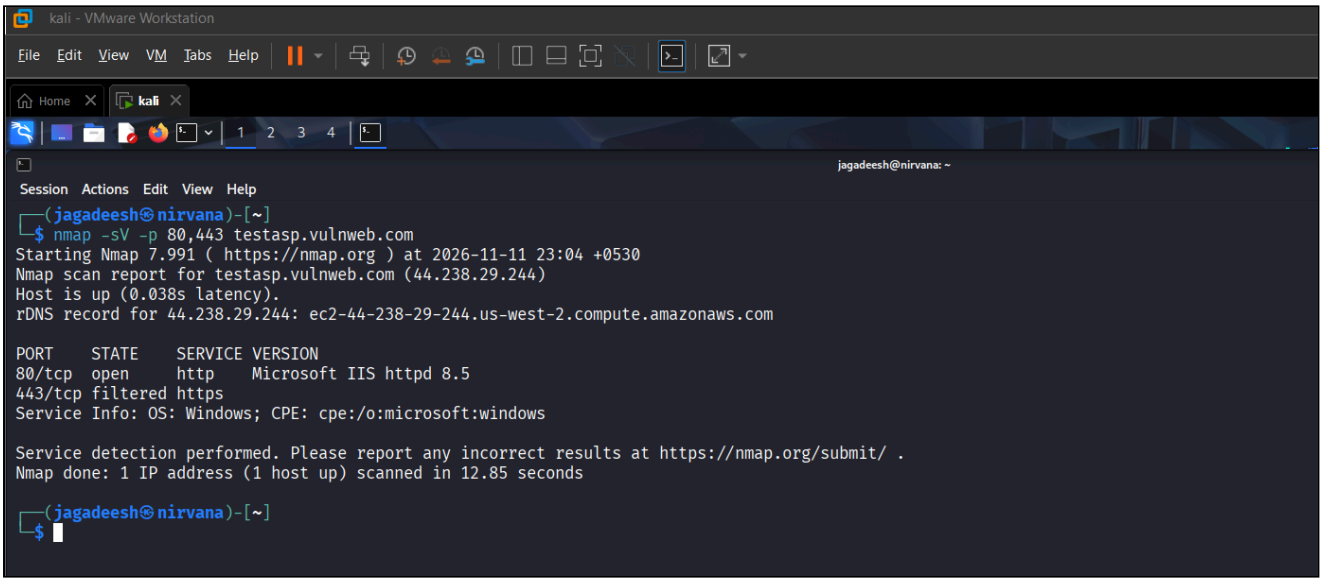
1) Insecure connection (Medium)

Description	If a website uses "http" instead of "https", all requests and responses can be read by anyone monitoring the session. "http" messages are plaintext, which means unauthorized parties can easily access and read them over the network. In contrast, "https" transmits all data in encrypted form. Port 80 is open while port 443 is filtered.
Impact	Medium
System	`http://testasp.vulnweb.com/`

Proof of concept:



Nmap Port Verification (Port 80 Open, Port 443 Filtered):



Recommendation:-

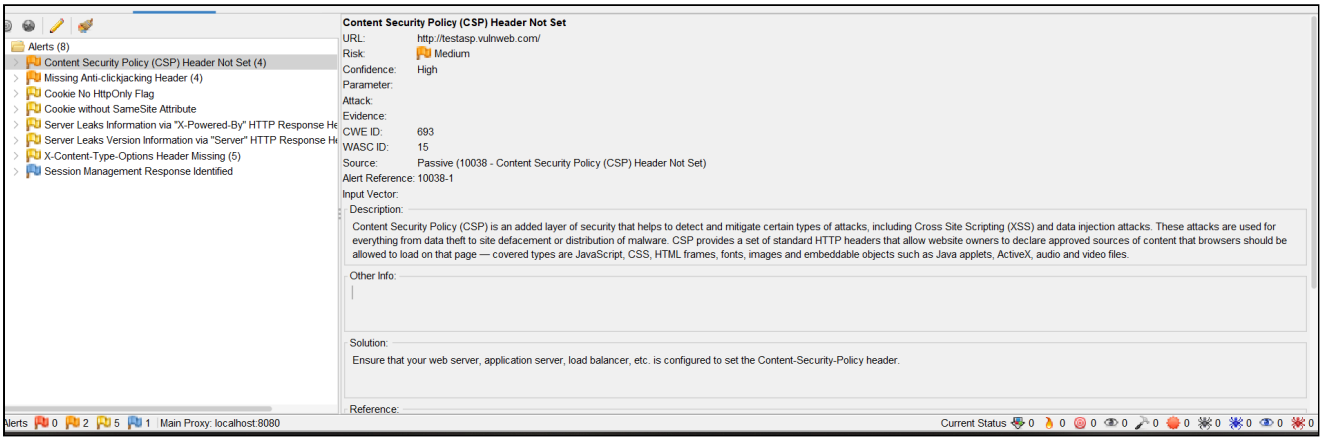
Change the webpage to "https".

1. **Obtain an SSL/TLS Certificate:** Obtain a trusted certificate from a Certificate Authority (CA).
2. **Install and Configure SSL:** Bind port 443 on IIS with the valid certificate.
3. **Enable HTTPS Redirection:** Configure your server to automatically redirect all HTTP traffic to HTTPS via 301 redirect.
4. **Implement HSTS:** Add the `Strict-Transport-Security: max-age=31536000; includeSubDomains` response header.

2) Clickjacking (Medium)

Description	The website is vulnerable to clickjacking (an attack that tricks a user into clicking a webpage element which is invisible or disguised as another element). This can cause users to unwittingly perform unintended transactions or reveal sensitive data. The HTTP response headers lack both `X-Frame-Options` and a CSP `frame-ancestors` directive, allowing the webpage to be embedded within an `<iframe>` on malicious domains.
Impact	Medium
System	`http://testasp.vulnweb.com/`

Proof of concept:



Recommendation:-

Implement X-Frame-Options header (Used to control whether a page can be placed in an <iframe>).

1. In the IIS `web.config` file, add the following line under `<customHeaders>`:

   ```
   <add name="X-Frame-Options" value="SAMEORIGIN" />
   ```

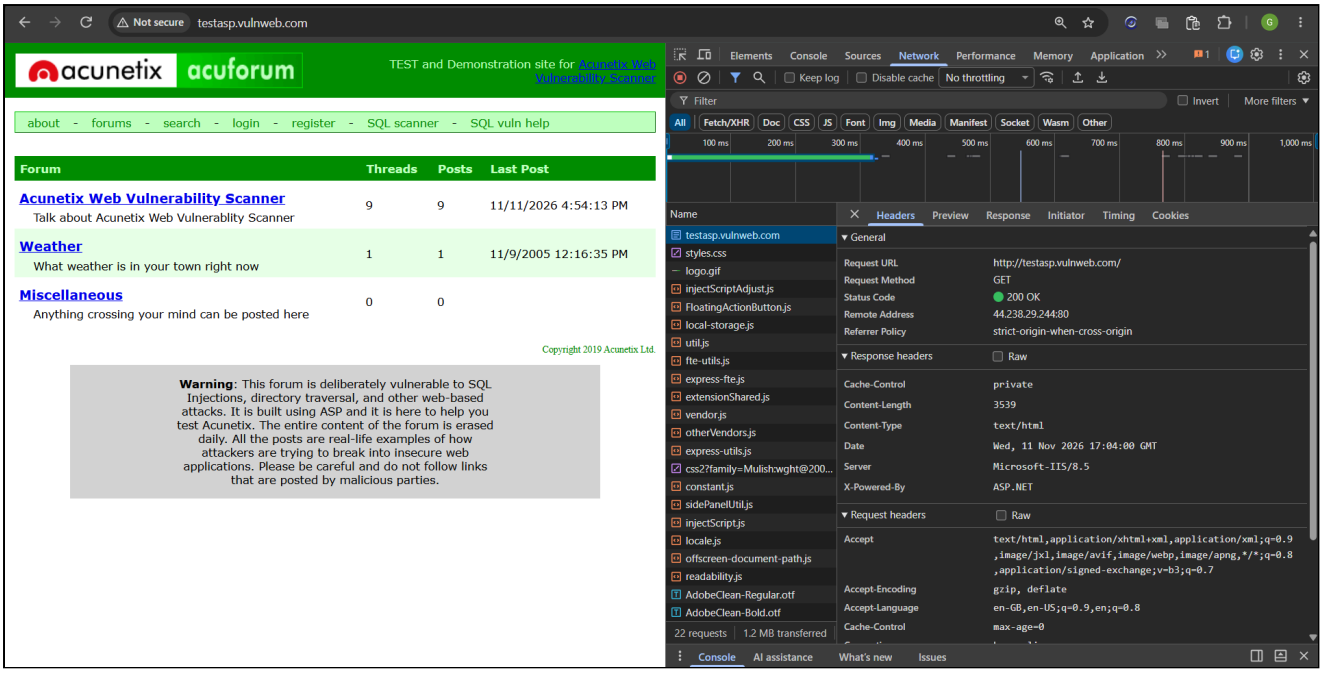
2. Alternatively, enforce framing restrictions within Content Security Policy using:

   ```
   Content-Security-Policy: frame-ancestors 'self';
   ```

3) Sensitive Information Disclosure (Low)

Description	The HTTP response headers disclose detailed server software versions and underlying framework components. Specifically, responses broadcast `Server: Microsoft-IIS/8.5` and `X-Powered-By: ASP.NET`. This permits attackers to perform precise reconnaissance and target known framework weaknesses.
Impact	Low
System	`http://testasp.vulnweb.com/`

Proof of concept:



Recommendation:-

Hide sensitive version contents from HTTP response headers.

1. Remove the `X-Powered-By` header via IIS Manager or by adding `<remove name="X-Powered-By" />` under `<customHeaders>` in `web.config`.
2. Configure the URL Rewrite module or URLScan in IIS to suppress or redact the `Server` banner.

4) Missing Content Security Policy (CSP) (Medium)

Description	Content Security Policy (CSP) is an added layer of security that helps detect and mitigate Cross-Site Scripting (XSS) and data injection attacks. The server currently returns no `Content-Security-Policy` response header.
Impact	Medium
System	`http://testasp.vulnweb.com/`

Recommendation:-

Ensure that the web server sets an appropriate Content-Security-Policy header.

1. Define allowed sources for scripts, styles, and media (e.g., `Content-Security-Policy: default-src 'self';`).

5) Insecure Cookie Attributes (Low)

Description	Cookies issued by the application are missing the `HttpOnly` and `SameSite` flags. Without `HttpOnly`, cookies can be accessed via malicious client-side JavaScript. Without `SameSite`, cookies are vulnerable to cross-site request forgery scenarios.
Impact	Low
System	`http://testasp.vulnweb.com/`

Recommendation:-

Configure cookie flags across the application.

1. Enable `httpOnlyCookies="true"` in `web.config` under `<httpCookies>`.
2. Set `SameSite=Lax` (or `Strict`) on all session management cookies.